

GUÍA METODOLÓGICA EXHAUSTIVA

Kit de Encuesta ENS 2026 - Administración de Aplicación

TABLA DE CONTENIDOS

1. Propósito y Alcance
2. Metodología QM Aplicada
3. Selección de Muestra y Participantes
4. Proceso de Administración
5. Interpretación de Respuestas
6. Cálculo del IGM (Índice de Gestión de Madurez)
7. Análisis Estadístico
8. Gestión de Riesgos en Aplicación
9. Confidencialidad y Governance
10. Cronograma Recomendado

1. Propósito y Alcance

1.1 Objetivos Primarios

Objetivo 1: Diagnóstico Basal

- Establecer línea base de madurez ciberseguridad en la organización
- Identificar brechas respecto a ENS, NIST CSF 2.0, NIS2
- Priorizar inversiones en ciberseguridad

Objetivo 2: Monitoreo Continuo

- Medir progreso año a año (comparativa longitudinal)
- Detectar degradación o mejora en postura de seguridad
- Apoyar decisiones de presupuesto y recursos

Objetivo 3: Benchmarking

- Comparar postura con pares sectoriales (si bases de datos disponibles)
- Identificar prácticas líderes en la industria
- Establecer metas realistas de madurez

1.2 Alcance Organizacional

La encuesta está diseñada para:

- **Administración Pública** (Central, Autonómica, Local)
- **Operadores Esenciales** (Energía, Agua, Transporte, Sanidad, Finanzas, TIC)
- **Operadores Importantes** (según NIS2)
- **Sector Privado** (todas las ramas)
- **Organizaciones de cualquier tamaño** (desde micro hasta mega)

2. Metodología GQM Aplicada

2.1 Fundamentos GQM (Goal-Question-Metric)

La encuesta sigue el enfoque **GQM** en tres niveles:

Nivel Conceptual (Goals/Objetivos):

Meta General: "Alcanzar madurez de ciberseguridad alineada a ENS"

- └─ Meta 1: "Conformidad completa con ENS"
- └─ Meta 2: "Detección proactiva de amenazas (MTTD < 24h)"
- └─ Meta 3: "Respuesta efectiva a incidentes (MTTR < 4h sistemas críticos)"
- └─ Meta 4: "Cultura de seguridad en toda la organización"

Nivel Operacional (Questions/Preguntas):

Cada meta se desglosa en 3-5 preguntas operacionales (P1-P114 en encuesta)

Nivel Cuantitativo (Metrics/Métricas):

Cada pregunta asigna puntuación según madurez (1-5 puntos típicamente)

2.2 Mapeo de Preguntas a Objetivos

Meta	Preguntas Asociadas	Dominio ENS
Marco Organizativo	P6-P16	Art. 12-16
Marco Operacional	P17-P35	Art. 18-31
Medidas Protección	P36-P50	Anexo II
Incidentes/Respuesta	P46-P68	Art. 33-34
Capacitación	P79-P94	Art. 27
Gobernanza	P95-P104	Transversal
Finanzas	P105-P109	ROI/Valor

3. Selección de Muestra y Participantes

3.1 Criterios de Selección

Muestra Recomendada:

- Para organizaciones < **100 personas**: 1 respondente mínimo
- Para organizaciones **100-500 personas**: 3-5 respondentes
- Para organizaciones > **500 personas**: 5-10 respondentes (multi-departamental)

Departamentos Involucrados:

1. **Seguridad de TI / CISO (40% peso)** - Perspectiva técnica
2. **Cumplimiento / Legal (20% peso)** - Perspectiva regulatoria
3. **Auditoría Interna (20% peso)** - Perspectiva de control
4. **Dirección Ejecutiva (10% peso)** - Perspectiva de negocio
5. **Recursos Humanos (10% peso)** - Perspectiva de concienciación

3.2 Método de Ponderación Multi-Departamental

Si múltiples respondentes de diferentes áreas:

$$\text{Puntuación Final} = (\text{CISO} \times 0,40) + (\text{Cumplimiento} \times 0,20) + (\text{Auditoría} \times 0,20) + (\text{Ejecutiva} \times 0,10) + (\text{RR.HH.} \times 0,10)$$

4. Proceso de Administración

4.1 Pre-administración (Semana -2 a 0)

Semana -2:

1. Identificar respondentes clave
2. Enviar invitación formal + contexto
3. Proveer acceso a encuesta (digital)

Semana -1:

1. Recordatorio a respondentes
2. Responder dudas sobre preguntas
3. Verificar acceso técnico a plataforma

Semana 0:

1. Lanzar encuesta oficialmente
2. Establecer fecha límite (2-3 semanas)
3. Crear canal de comunicación para preguntas

4.2 Durante Administración (Semana 1-3)

Semana 1:

- 40-50% de respuestas esperadas
- Recordatorio gentil a falta de respuesta

Semana 2:

- 70-80% de respuestas esperadas
- Recordatorio más formal a rezagados

Semana 3:

- Cierre de encuesta
- Seguimiento telefónico si < 90% respuesta

4.3 Post-administración (Semana 4+)

11. Consolidación de datos (2-3 días)
12. Análisis estadístico (1 semana)
13. Elaboración de reporte (1-2 semanas)
14. Presentación a stakeholders (semana 4)

5. Interpretación de Respuestas

5.1 Esquema de Puntuación por Pregunta

Cada pregunta tiene 5-6 opciones que mapean a niveles de madurez NIST:

Opción	Madurez NIST	Puntuación	Caracterización
1 (Peor)	Inexistente/Parcial	1	Ad-hoc, informal
2	Informado por Riesgo	2	Procesos iniciales
3	Repetible	3	Procesos estandarizados
4	Adaptativo	4	Procesos mejorados continuamente
5 (Mejor)	Optimizado	5	Mejora continua automática

5.2 Interpretación Cualitativa de Respuestas

Sección II (Marco Organizativo):

- Puntuación 1-2 → Riesgo de gobernanza alta
- Puntuación 3 → Gobernanza básica establecida
- Puntuación 4-5 → Gobernanza madura

Sección III (Marco Operacional):

- Puntuación 1-2 → Operaciones caóticas
- Puntuación 3 → Operaciones documentadas
- Puntuación 4-5 → Operaciones optimizadas

Sección VI (Penetración Testing):

- Ausencia de pruebas → Vulnerabilidades desconocidas
- Anual → Cumplimiento mínimo
- Trimestral+ → Vigilancia continua

6. Cálculo del IGM (Índice de Gestión de Madurez)

6.1 Fórmula Base del IGM

$$IGM = \frac{\sum(\text{Puntuación_pregunta} \times \text{Peso_pregunta})}{\sum(\text{Pesos})}$$

Escala: 1.0 - 5.0 (donde 5.0 es excelencia total)

6.2 Asignación de Pesos por Dominio

Dominio	Preguntas	Peso	Justificación
Marco Organizativo	P6-P16	20%	Base de seguridad
Marco Operacional	P17-P35	25%	Ejecución diaria
Medidas Protección	P36-P50	20%	Defensa técnica
Respuesta Incidentes	P46-P68	15%	Resiliencia
Capacitación	P79-P94	10%	Factor humano
Gobernanza	P95-P104	10%	Control y cumplimiento

6.3 Cálculo Paso a Paso

Ejemplo Organizacional:

```
Pregunta | Respuesta | Puntos | Peso | Contribución
-----|-----|-----|-----|-----
P6 (Política) | 4 | 4,0 | 0,05 | 0,20
P7 (Objetivos) | 3 | 3,0 | 0,05 | 0,15
P8 (Comunicación) | 2 | 2,0 | 0,05 | 0,10
...
P114 (Tech Emergentes) | 3 | 3,0 | 0,01 | 0,03
IGM = (0,20 + 0,15 + 0,10 + ... + 0,03) = 3,47
```

6.4 Benchmarks e Interpretación del IGM

Rango IGM	Clasificación	Estado	Acción Recomendada
1,0 - 1,9	Crítico	Riesgo extremo	Intervención inmediata
2,0 - 2,9	Insuficiente	Riesgo alto	Plan de mejora acelerado
3,0 - 3,4	Básico	Riesgo medio	Plan de maduración anual
3,5 - 4,2	Avanzado	Riesgo bajo	Consolidación y optimización
4,3 - 5,0	Excelencia	Riesgo mínimo	Liderazgo sectorial

7. Análisis Estadístico

7.1 Medidas de Dispersión

Desviación Estándar:

$$\sigma = \sqrt{[\sum(x - media)^2 / N]}$$

Si $\sigma > 1,0$ – Respuestas inconsistentes entre departamentos

Rango Intercuartílico (IQR):

Identifica outliers en respuestas por pregunta

7.2 Análisis de Correlación

Preguntas a correlacionar:

- **P46 (Procedimiento incidentes) vs P47 (MTTD)**: Relación entre documentación y capacidad
- **P79 (Capacitación) vs P88 (Cambio comportamiento)**: Efectividad de concienciación
- **P105 (Gasto) vs IGM**: ¿Gasto = Madurez? (esperado: correlación positiva moderada)

7.3 Análisis de Brecha (Gap Analysis)

Brecha_dominio = IGM_objetivo (4,0) - IGM_actual

Ejemplo: Si IGM = 3,1 actual, brecha = 0,9 puntos
Esto requiere inversión / plan de mejora

8. Gestión de Riesgos en Aplicación

8.1 Sesgos Potenciales

Sesgo	Causa Probable	Mitigación
Sobrevaloración	Auto-reporte optimista	Validación con auditoría
Infravaloración	Temor a crítica	Confidencialidad garantizada
Falta de conocimiento	Respondente desconoce área	Múltiples respondentes
Respuestas rápidas	Falta de reflexión	Recordatorio de completitud

8.2 Validación de Respuestas

Cross-checks internos:

1. Si P17 (Plan seguridad) = 1, pero P79 (Capacitación) = 5 → Inconsistencia → Investigar
2. Si P69 (SIEM) = 1, pero P47 (MTTD) < 24h → Inconsistencia → Investigar

Validación externa:

- Comparar contra hallazgos de auditoría reciente
- Verificar contra políticas documentadas

9. Confidencialidad y Governance

9.1 Protección de Datos

- Encuesta anónima (identificador de organización, no de individuo)
- Transmisión cifrada (HTTPS, encriptación TLS 1.3+)
- Almacenamiento seguro (base de datos con acceso restringido)
- Retención limitada (destrucción después de análisis, máx. 2 años)

9.2 Consenso de Consentimiento

Obtener autorización firmada de:

- [] CISO/Responsable de Seguridad
- [] Cumplimiento/Legal
- [] DPO (si organización > 100 personas)

10. Cronograma Recomendado

Ciclo Anual Sugerido

Mes	Actividad
Enero-Febrero	Planificación, selección de muestra
Marzo-Abril	Administración de encuesta
Mayo-Junio	Análisis, elaboración de reporte
Julio	Presentación de hallazgos
Agosto-Septiembre	Planificación de mejoras
Octubre-Diciembre	Implementación de mejoras identificadas

Cadencia de Encuesta

- Inicial: Línea base (Año 1)
- Anual: Reencuesta completa (Año 2+)
- Trimestral: Mini-encuesta de seguimiento (preguntas clave)

Conclusión

Esta guía metodológica asegura **consistencia, rigor y comparabilidad** en la aplicación de la encuesta integral de ciberseguridad. El enfoque GQM garantiza vinculación directa entre preguntas operacionales y objetivos estratégicos de seguridad.

Versión: 1.0

Última actualización: 24 enero 2026